

UAS Q&A KBA Implementation Guide - 6.0.1-GA (AI)

Table of Contents

1. Preface - UAS Q&A KBA Implementation Guide.....	3
2. Introduction to UAS Q&A KBA Implementation.....	4
3. UAS Q&A KBA Configuration.....	5
4. UAS Q&A KBA Implementation Using API.....	8

1. Preface - UAS Q&A KBA Implementation Guide

This document provides the concept, implementation steps and API integration details of AccessMatrix Universal Authentication Server (UAS) Question & Answer Knowledge-based Authentication (KBA) authentication method.

Intended Reader

This document is intended as a reference for security administrators, i-Sprint's Professional Service personnel, and developers.

Document Scope

This document contains information on carrying out the following operations:

- Integrate Q&A KBA with AccessMatrix server for authentication purposes.
- Implement Q&A KBA authentication using API.

For any feedback or questions regarding this document, contact doc@i-sprint.com.

Related Documents

For more information, see the following documents in the AccessMatrix Product Suite:

- [AccessMatrix Common Administration Guide](#)
- [AccessMatrix REST API Specification](#)

2. Introduction to UAS Q&A KBA Implementation

This document provides the instructions on the configuration and API integration of Q&A KBA.

About Q&A KBA

Question & Answer (Knowledge-based Authentication) - Q&A KBA for short - is an alternative authentication method to authenticate a user based on what the user knows (knowledge that the user knows). The answers are set by the users beforehand based on a set of questions predefined by an administrator. Normally, this authentication method is used as a password recovery method when no other suitable method is available. For password recovery, the better solution is to use Email/SMS OTP or Token Challenge Response. Q&A KBA can also be used as an additional layer of security on top of the Email/SMS OTP or Token-based authentication.

Examples of questions:

- What is your mother's family name?
- What is your favorite color?

The user can then choose the answers from the set of questions. When the user needs to be authenticated using Q&A KBA, the answers must be an exact match in term of spelling, but it is case-insensitive (to keep it simple and to avoid user frustration if they do not remember the cases they used when setting the answer).

For security purpose, the user's answers are handled similarly to how the AccessMatrix Server handles the password. This means the answers are never stored in clear text. In the case of this Q&A KBA, each answer is salted and hashed using SHA2-512.

Implementation Checklist

Below is the checklist for implementing UAS Q&A KBA solution.

Tasks	Reference
Configure Q&A KBA Login Module	Q&A KBA Login Module
Configure the Authentication Realm	Authentication Realm

3. UAS Q&A KBA Configuration

Configure Q&A KBA Login Module

A Q&A KBA login module needs to be created to determine the set of questions and other authentication matching configuration, such as the number of questions that the user must be able to answer correctly.

1. Navigate to **Administration Dashboard > Configuration > Authentication > Login Module**.
2. Click **Create** and select the "Q&A KBA Login (one step)" implementation from the **Choose Login Module Implementation** page. Then, click **Next**.
3. Enter a **Login Module Id** (e.g. "qakba") and a **Login Module Name** (e.g. "Questions and Answers").
4. Select the **Login Policy** and the **Authentication Level** values, if necessary.
5. Enter the login module attributes as described in the table below.
6. Click **Save**. A new login module is created.

Attribute Name	Description
*User Login Module Id	Unique Id of user login module, e.g. "qakba".
*User Login Module Name	Name of user login module, e.g. "Questions and Answers".
Description	Description of user login module.
Version	User login module entry version.
Attributes Tab	
*Login Policy	Login policy to apply to this authentication method. The login policy determines the number of invalid authentication attempts allowed before the account is locked.
*Authentication Level	Authentication level to be assigned to this authentication method. This is normally used by other modules to allow access to the user only if the user is authenticated with a certain authentication level.
Q&A KBA Login Policy (one step)	

Attribute Name	Description
Minimum No. of Correct Responses	Minimum number of correct responses/answers for the user authentication to be considered successful.
Questions (Updating a question is not recommended as it might change the meaning of existing users' answers.)	
This contains configurations of the set of questions to be asked to the users. Updating a question once it has been used is not recommended, as it changes the question only.	
(1 - 10)	Specify the question that the user needs to answer.

Configure Authentication Realm

1. Navigate to **Administration Dashboard > Configuration > Authentication > Authentication Realm**.
2. Click **Create**.
3. Enter an **Authentication Realm Id** (e.g. "qakba") and an **Authentication Realm Name** (e.g. "Questions and Answers").
4. Specify the **User Lookup Module** value that will be used to validate user identity, "e.g. System Lookup (40151)".
5. Specify the **First(1st) Login Module** that will be used for user authentication, e.g. "Questions and Answers (qakba)".
6. Click **Save**. A new authentication realm is created.

Assign Login Accounts to User

A user may belong to a default store or external user store. You may refer to [AccessMatrix Common Administration Guide - Manage User Stores](#) to know about the different types of user stores and how to configure it.

To create a new user in default store, navigate to **Operation Dashboard > User & Segment > User** and click **Create** on the right pane. Provide values to the following attributes that are necessary for Q&A KBA implementation before saving the changes.

Attribute Name	Description
*User Id	Unique user Id, e.g. "user01".
*User Name	Name of user, e.g. "user01".
*Interactive	Set to "Yes" to make it an interactive user.
User Store	Name of user store the user belongs to, i.e. "Default Store".
Login Accounts Tab	
This tab contains the authentication realm and login module assigned to user. Click Add to display the Choose Authentication Realm dialog box. Select the authentication realm created in previous section (e.g. "Questions and Answers (qakba)") and click OK. Both authentication realm and the login module(s) associated to it will be assigned to the user.	

Click **Save**. A new user is created.

You may refer to [AccessMatrix Common Administration Guide - Manage Users](#) for detailed information about users.

4. UAS Q&A KBA Implementation Using API

Setting Answers (Reset and Change Password)

Before the user can use Q&A KBA authentication, the user needs to answer some of the questions. How the application asks the user on which questions to answer is flexible. The application will call the API to set all of the user's answers in the API call. This allows flexibility for the application to determine whether it will display the set of questions one-by-one or in full. The application can also allow the user to choose the questions to answer as long as the number of answered questions is at least more than the configured **Minimum No. of Correct Responses**.

For the user to answer the questions, the application can call the Change Password (/password/change) API using the user's valid session token (assuming the user has been authenticated using other method beforehand).

Alternatively, the application can use a dynamic agent session with reset password privilege to call the Reset Password (/password/reset) API to set the user's answers on the user's behalf. You can also use an access token to call the Reset Password API - refer to the details provided in [Using AccessMatrix REST APIs - Configuring Authentication Methods for Accessing AccessMatrix REST APIs](#).

REST Sample Code for /password/reset

- Use /password/reset to set the user's answers using dynamic agent session with reset password privilege to set user's answers on behalf of the user.
- Refer to the [AccessMatrix REST API Specification](#) for more details.

Sample Request for setting answers using reset password API (REST)	
Request	JSON
	<pre>{ "dynamicAgentSession": true, "userId": "demouser", "userStoreId": "", "loginModuleId": "qakba", "password": "{ \"q2\": \"Brownie\", \"q3\": \"Maths\", \"q4\": \"salt\"}" }</pre>

- The password is in JSON string format. Thus, in the REST API, it needs to be escaped to be considered as one string of password.
-

- Answers are set using JSON key value where the key can be q1, q2, q3, ..., or q10.
- The answers will be matched in case-insensitive manner during authentication. Spaces and punctuation will be matched too.
- The answers provided will replace the set of answers that the user had previously set, if any. This means if the user had previously answered q1, q2, and q3 and then this API is called with only q3, q4, and q5 provided, the final answers set for the user will only be q3, q4, and q5. The answers that previously set for q1 and q2 will be removed. In other words, the API sets the whole set of answers for the user replacing the whole set of answered set previously.

REST Sample Code for /password/change

- Use /password/change to set the user's answers using user's own session (assuming the user has been authenticated using other authentication method).
- Normally, the Change Password API requires current password to be verified before change password takes place. However, for this Q&A KBA, the old password is not verified.
- Refer to the [AccessMatrix REST API Specification](#) for more details.

Sample Request for setting answers using change password API (REST)	
Request	
JSON	<pre>{ "sessionToken": ".....", "userId": "demouser", "userStoreId": "", "loginModuleId": "qakba", "oldPassword": "", "newPassword": "{ \"q2\": \"Brownie\", \"q3\": \"Maths\" , \"q4\": \"salt\"}" }</pre>

- The password is in JSON string format. Thus, in the REST API, it needs to be escaped to be considered as one string of password.
- Answers are set using JSON key value where the key can be q1, q2, q3, ..., or q10.
- The answers will be matched in case-insensitive manner during authentication. Spaces and punctuation will be matched too.
- The answers provided will replace the set of answers that the user had set previously, if any. This means if the user had previously answered q1, q2, and q3 and then this API is called with only q3, q4, and q5 provided, the final answers set for the user will only be q3, q4, and q5. The

answers that previously set for q1 and q2 will be removed. In other words, the API sets the whole set of answers for the user replacing the whole set of answered set previously.

Authentication using Q&A KBA (login)

After the user has answered the questions, when application needs to ask the user to challenge the user with Q&A KBA, application needs to ask the user's identity. Application can then call the Login API with the user's identity to get the list of questions that the user has answered. On how the application shows the question to the user is up to the application. What's important is that the application should ask the questions that has answers already set by the user. It is possible to simply list all the questions in one screen. Another way is to allow the user to choose the question to answer one by one. It is also possible for application to randomly display the questions.

After the user has provided the answers, application can call the Login API (/authn/login) with the user's answers mapped to corresponding questions. Alternatively, the Verify Password API (/password/verify) can also be used to verify user's answers. The difference is that the Login API creates a user session and produces a session token to represent the user's session, whereas the Verify Password API will only validate whether the provided answers are correct and no user session is generated.

REST Sample Code with empty password to get list of questions to ask the user

- Use /authn/login with a userId and an empty password to get the list of questions and indicators of the questions with answers already set by the user.
- Refer to the [AccessMatrix REST API Specification](#) for more details.

Sample Request with empty password to get the valid questions to ask the user (REST)	
Request	
JSON	
<pre>{ "realmId": "qakba", "userId": "demouser", "password": "" }</pre>	
Response	
JSON	

Sample Request with empty password to get the valid questions to ask the user (REST)

```
{
  "result": {
    "attr.LT": "1622584381017",
    "authenticated": false,
    "sessionIID": "m0u-jCn6oH9VLUHe8LmTpw",
    "lastAccessTime": 1622512381046,
    "realmId": "qakba",
    "sessionFlags": 0,
    "serverId": "andyaml",
    "userId": "demouser",
    "attr.IT": "36000",
    "expiresAt": 1622584381,
    "realm.lastLoginSuccessTime": 0,
    "sessionToken":
    "15BB1m6ZwS9dlGi7Mtzjszmtw...(truncated in
    document)...QxHqMSpkPRJprli2LHKmID0zjC_VEEBo",
    "challenge": {
      "authenticationCode": 18888,
      "message": "For successful verification user
      must give minimum 2 successful answers.",
      "params": {
        "q1": "What is your favourite colour?",
        "a1": false,
        "totalQuestions": 4,
        "q2": "What is your dog's name?",
        "a2": true,
        "q3": "What is your favourite school
subject?",
        "minNumOfCorrectResponses": 2,
        "a3": true,
        "q4": "What is the secret ingredient for
your favourite dish?",
        "a4": true,
        "numOfAnswersSet": 3,
        "isSettingAnswersRequired": false
      },
      "responses": {},
      "idleTimeOutInSecs": 36000,
      "userUUID": "nzrdUnj_mk",
      "loginModuleStates": [
        {
          "authenticated": false,
          "canChangePassword": true,
          "id": "qakba",
          "loginModuleHandlerClass":
          "QAndAKBLoginInBulkAnswers"
        }
      ],
      "attr.regenerated": "1622512381047"
    },
    "amProcessingTimeMillis": 35
  }
}
```

- Q&A KBA related information is provided in the result/challenge/param JSON structure.

- q1 - q10 indicate the questions as configured in the login module. a1 - a10 indicate whether the user has set an answer to the question corresponding to the same index number (e.g. a1 ==> q1, a5 ==> q5, etc.).
- minNumOfCorrectResponses indicates the number of correct answers that must be provided by the users. The application can use this number to enforce that the user provides at least this number of answers.
- isSettingAnswersRequired indicates whether the user has set the required minimum number of answers. Thus, this user will not be successfully authenticated using Q&A KBA.
 - If this API is called as part of Q&A KBA challenge, then the application should not allow the user to proceed and instead the user must be challenged using another method.
 - If this API is called just to check whether the user has set the minimum number of answers, then application should ask the user to set the answers.
- numOfAnswersSet indicates the number of questions with answers already set by the user.

REST Sample Code to validate user's answers

- Use /authn/login with user Id and user-provided answers.
- The Login API (/authn/login) produces an authenticated session token for the user when verification is successful. If authenticated session token is not required, use /password/verify instead.
- Refer to the [AccessMatrix REST API Specification](#) for more details.

Sample Request with user-provided answers(REST)	
Request	
JSON	
<pre>{ "realmId": "qakba", "userId": "demouser", "password": "{ \"q2\": \"Brownie\", \"q3\": \"Maths\"}" }</pre>	
Response	
JSON	
<pre>{ "result": { "attr.LT": "1622588210095", "authenticated": true, } }</pre>	

Sample Request with user-provided answers(REST)

```
"sessionIID": "L0UelluYUdfSmMqpIdMwmQ",
"lastAccessTime": 1622516210112,
"realmId": "qakba",
"sessionFlags": 1,
"serverId": "andyam1",
"userId": "demouser",
"attr.IT": "36000",
"expiresAt": 1622588210,
"realm.lastLoginSuccessTime": 1622516144000,
"loginTime": 1622516210095,
"sessionToken":
"15BB1A_36tKcNtuyOyAlzEL...(truncated in
document)...vjzt0Slea7QP8EjafEQc4FGq1I",
"idleTimeOutInSecs": 36000,
"userUUID": "nzrdUnj_mk",
"loginModuleStates": [
  {
    "authenticated": true,
    "canChangePassword": true,
    "id": "qakba",
    "loginModuleHandlerClass":
"QAndAKBALoginInBulkAnswers"
  }
],
"attr.regenerated": "1622516210125"
},
"amProcessingTimeMillis": 31
}
```

- The password is in JSON string format. Thus, in the REST API, it needs to be escaped to be considered as one string of the password.
- Answers are set using JSON key value where the key can be q1, q2, q3, ..., or q10.
- The answers will be matched in case-insensitive manner during authentication. Spaces and punctuation will be matched too.
- The number of provided answers must satisfy the **Minimum No. of Correct Responses** as specified in the login module configuration. If the **Minimum No. of Correct Responses** is set to "2" and the user only answers one question correctly, then the authentication is considered unsuccessful and it is taken that wrong password is provided.
